

Gouvernance des données et de l'IA

Spotify · Présentation au comité exécutif

Adrien COSSON · RNCP 41993 · Bloc 1

7 Octobre 2026

Pourquoi agir maintenant

Le business case en quatre chiffres (en date de 2023)

450 M+

utilisateurs actifs, dont 200 M abonnés Premium

180+

pays, avec autant de cadres réglementaires

≈ 5 M€

d'amende de l'IMY en 2023 pour des réponses d'accès incomplètes

4 %

du chiffre d'affaires mondial: plafond des amendes RGPD

La donnée est le principal avantage de Spotify face à Apple Music, Amazon Music ou YouTube Music.

La problématique et comment y répondre

Mais chaque département gère ses données avec ses propres règles : silos, problèmes de qualité, risques de conformité.

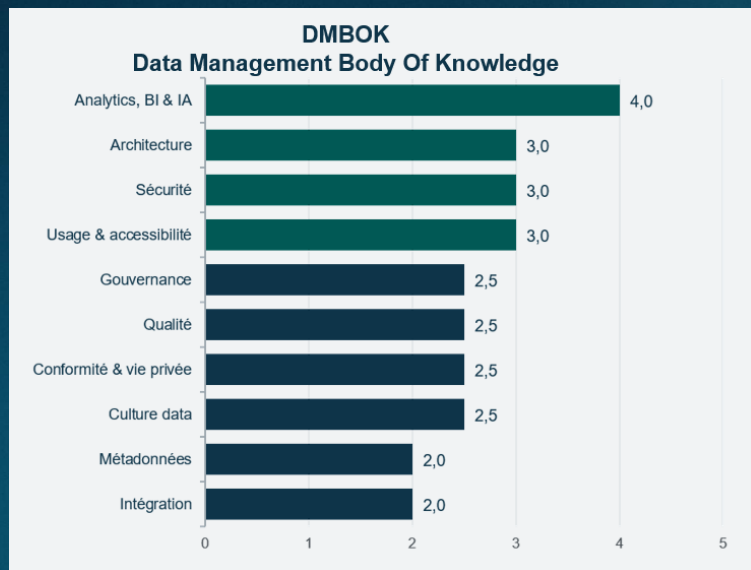


Diagnostic : une maturité de 2,7 sur 5

Data Maturity Assessment Template + métadonnées (DMBOK)

Echelle de Gartner: 1 – Aware < 2 – Reactive < 3 – Proactive < 4 – Managed < 5 – Effective

Data Management Body of Knowledge (DMBOK): 9 différentes dimensions + métadonnées



2,7 / 5

entre « Reactive » et « Proactive »

Forts : excellente exploitation des données

Faibles : gouvernance pas à l'échelle de l'entreprise.

**L'enjeu n'est pas de
reconstruire, mais de
fédérer**

Cible : « Managed », environ 4 sur 5, en 18 mois.

Sept défis, classés par priorité

Les défis C1 à C7 structurent la politique (L2) et le plan (L3)

Priorité 1 · pilote (0-6 mois)

C1

Supprimer les silos : identifiant utilisateur commun

C2

Industrialiser les droits des utilisateurs et le consentement

C3

Documenter les données : catalogue, marquage des données personnelles

Priorité 2 · 6-12 mois

C4

Fiabiliser la qualité : règles communes, data contracts

C5

Renforcer la sécurité : accès selon la sensibilité, chiffrement

Priorité 3 · 12-18 mois

C6

Encadrer l'IA : biais, explicabilité, contenus générés par IA

C7 · Former à la gouvernance : en continu, dès le premier mois

Politique : neuf principes de gouvernance

« *Governance Principles Guide* »

Neuf principes de gouvernance

Qualité	Sécurité	Conformité		IA
4 · Qualité des données	3 · Sécurité des données	2 · Transparence	5 · Conformité	9 · Usage éthique de l'IA
		6 · Minimisation	7 · Droits des utilisateurs	

Transverses : 1 · Redevabilité · 8 · Amélioration continue

Quatre niveaux de classification pour déterminer les accès

Public	Interne	Confidentiel	Restreint
--------	---------	--------------	-----------

Le niveau de chaque donnée, inscrit dans le catalogue, fixe qui peut y accéder, combien de temps elle est conservée et si elle peut être partagée.

Un modèle fédéré : le Centre d'Excellence

Modèle recommandé par l'Executive Q&A Guide et Organizational Models

Type d'organisation recommandée
Centre d'Excellence (CoE)

1 équipe centrale définit les règles et fournit les outils

Chaque département reste responsable de ses données



Conformité : les 14 exigences de la checklist

Compliance Checklist (RGPD 5, CCPA 3, PCI-DSS 6) + AI Act

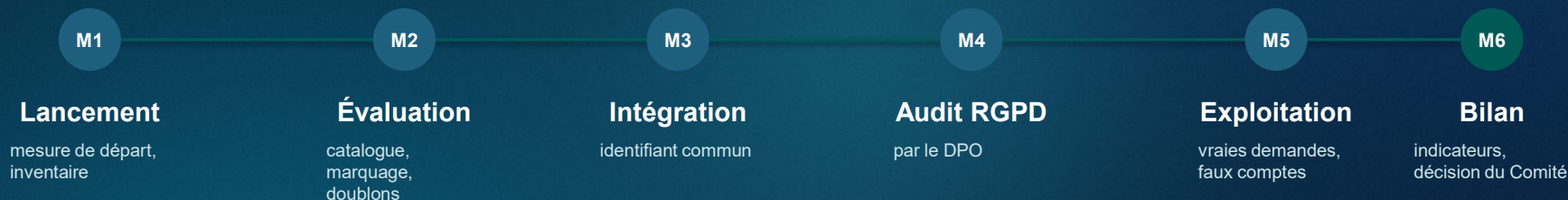
RGPD Union européenne	CCPA Californie	PCI-DSS Données de paiement	AI Act Systèmes d'IA
Traitement licite et transparent Droits d'accès et de suppression Consentement explicite Violation notifiée sous 72 h DPO désigné	Refus de la vente des données Accès et suppression Aucune discrimination	Tokenisation chez le prestataire Chiffrement, accès limités Surveillance et tests réguliers	Niveau de risque qualifié Revue des biais avant mise en ligne Contenus IA signalés

RGPD comme référence pour tous ; en cas de conflit, la règle la plus protectrice pour l'utilisateur s'applique.

Le pilote : droits des utilisateurs en Suède

Pilot Template · 6 mois

Pourquoi ce choix: risque réel (motif de l'amende de 2023 à l'encontre de Spotify)
résultat mesurable facilement (délai de réponse, complétude, automatisation)
il oblige à construire les fondations (catalogue, marquage des données, identifiant unique)



Équipe

Chef de projet (rattaché au CDO) · DPO · Data Owners · Data Stewards du marketing, du développement produit et de l'ingénierie · Data Engineers

Formation à la gouvernance

Bien former pour mieux gouverner

Une politique non comprise reste sur le papier, alors qu'une politique acceptée est déployée.

Spotify a une culture de la data, mais celle-ci n'unifie pas les différents départements pour une gouvernance forte.

Tous les collaborateurs

Module court et obligatoire

1

Equipes du pilote

Ateliers pratiques

2

Rôles spécialisés

Parcours dédiés

3

Documentations, tutoriels, questionnaires, retours utilisateurs

100 % de l'équipe du pilote formée avant le mois 3

Indicateurs de succès et valeur attendue

Les quatre familles d'indicateurs

QUALITÉ

-10 %

de champs manquants dans les profils

CONFORMITÉ

≤ 15 j

pour répondre à une demande (légal : 1 mois)

ACCÈS

-20 %

de temps pour accéder à une donnée

ADOPTION

100 %

de l'équipe formée avant le mois 3

Coûts

Achat des outils, formation et personnel.
Budget précis établi au lancement par le CDO.

Valeur

Risque de sanction réduit (≈ 5 M€ en 2023, jusqu'à 4 % du CA)

Recommandations plus fiables

Accès plus rapide.

Les fondations du pilote servent à toute la suite.

Feuille de route et décisions attendues

Mois 1 à 6

Pilote en Suède

droits des utilisateurs, consentement, catalogue, identifiant commun

Mois 7 à 12

Extension

Union européenne et Californie (CCPA), data contracts, accès par niveau

Mois 13 à 18

Généralisation

autres pays, gouvernance de l'IA ; cible « Managed »

Nous vous demandons aujourd'hui de :

- 1 Valider la politique de gouvernance et créer le Comité de gouvernance
- 2 Lancer le pilote de 6 mois, avec un budget établi au lancement par le CDO
- 3 Nommer le chef de projet et les Data Stewards des départements concernés

Merci !

Questions et échanges